

	POLITIKE I PROCEDURE	
	Datum usvajanja:	1 / 7
	V1: 01-01-2025	
	POLITIKA BEKAPA ZA HIS	AKAZ Standard 1.15 (2020) Kriterij: 1.15.21
Odobreno od:  Medicinski direktor Doc. dr. Azur Tulumović, dr. med.  Direktor ASA Bolnice Prof. dr. Mustafa Hiroš, dr. med		

1. OPĆA IZJAVA

- 1.1.** ASA Bolnica prepoznaje važnost pouzdanog, sigurnog i neprekidnog rada bolničkog informacionog sistema (HIS) kao temelja za osiguranje kontinuiteta pružanja zdravstvenih usluga, zaštitu medicinskih i administrativnih podataka, te ispunjavanje regulatornih i akreditacijskih zahtjeva.
- 1.2.** U skladu s tim, uspostavlja se jasna politika pravovremenog i sigurnog bekapa HIS sistema, sa ciljem da se:
- 1.2.1. osigura redovno arhiviranje svih ključnih podataka iz HIS-a, uključujući medicinsku dokumentaciju, podatke o pacijentima, nalaze, zakazivanja, finansijske i upravljačke informacije,
 - 1.2.2. minimizira rizik od gubitka podataka uslijed tehničkih grešaka, sigurnosnih incidenata, kvarova opreme ili drugih nepredviđenih okolnosti,
 - 1.2.3. omogućiti brz i tačan povrat podataka (restore) u slučaju prekida u radu sistema,
 - 1.2.4. poštuju pravila informacione sigurnosti, uključujući kontrolu pristupa, enkripciju, nadzor nad procesima, kao i usklađenost sa zakonskim i regulatornim okvirom (uključujući Zakon o zaštiti ličnih podataka).
- 1.3.** Politika bekapa HIS sistema definiše vrstu, učestalost, lokaciju i odgovornosti za provođenje bekapa, kao i period čuvanja bekapiranih podataka.
- 1.4.** Odgovornost za implementaciju, nadzor i periodično testiranje integriteta bekapa snosi IT odjel. Validacija ispravnosti bekapa i povremene simulacije restauracije podataka vrše se po procjeni IT menadžera, uz vođenje zapisnika i izveštavanje uprave bolnice.

2. PODRUČJE PRIMJENE

- 2.1.** Ova politika se odnosi na sve aktivnosti vezane za sigurnosno kopiranje (bekap) i obnavljanje (restore) podataka unutar Hospital Information System (HIS) sistema. Primjenjuje se na cjelokupni medicinski, administrativni i tehnički sadržaj koji se vodi, pohranjuje ili procesira kroz HIS, uključujući podatke o pacijentima, zdravstvenu dokumentaciju, nalaze, zakazivanja, fakturiranje i upravljačke informacije. Politika obuhvata rad IT službe, kao i sve vanjske partnere koji su angažovani na održavanju HIS sistema ili infrastrukture za bekap i sigurnost podataka.

3. DISTRIBUCIJA I NADZOR

- 3.1.** Politika se elektronski distribuira putem internog mrežnog sistema (intraneta).
- 3.2.** Dokument je dostupan svim relevantnim zaposlenicima.
- 3.3.** Za pravilnu primjenu politike odgovoran je menadžer IT odjela, koji u saradnji sa IT uposlenicima i vanjskim partnerima osigurava da se svi definisani procesi bekapa redovno provode, dokumentuju i testiraju.

3.4. Stalni nadzor nad poštivanjem politike vrši IT menadžer, dok Odjel kvaliteta ima zadatak da kroz interne revizije, kvartalne provjere i godišnje evaluacije nadgleda usklađenost sa ovom politikom i drugim relevantnim procedurama.

4. BOLNIČKI INFORMACIONI SISTEM (BIS)

4.1. Bolnički informacijski sistem (BIS) je usluga korisnicima koja omogućava bespapirno poslovanje, zakonski usklađeno i učinkovito upravljanje dokumentacijom uz maksimalnu sigurnost i zaštitu podataka, na lokalnoj IT infrastrukturi ASA Bolnice. Usluga se isporučuje u visoko standardiziranom i sigurnom formatu "Software-As-A-Service" i kao takva donosi jednostavnost korištenja uz maksimalnu sigurnost korisničkih podataka.

5. ARHITEKTURA PLATFORME ZA PRUŽANJE SaaS-a BIS

5.1. Cloud infrastruktura uspostavljena je u dva data centra. Primarni data centar je na lokaciji sjedišta ASA Bolnice, te Disaster Recovery data centar na lokaciji BH Telecom Sarajevo.

5.2. Sve kritične komponente primarnog data centra su redundantne i visokodostupne sa visokim nivoom sigurnosti i zahtijevanim performansama.

5.3. U pružanju SaaS usluge BIS koriste se dokazane prakse i provjereni proizvođači softvera poput VMware, Veeam, Lenovo, Aruba i Fortinet.

5.4. Sve komponente storage-a, computing-a, networking-a i security-ija primarnog i DR data centra su potpuno virtualizirane.

5.5. Sigurnosne politike realiziraju se provjerenim Fortinet security rješenjima NGFW (Next Generation Firewall) te WAF (Web Application Firewall) dok se politike neophodne za ostvarenje Business Continuity plana i Disaster Recovery plana implementiraju korištenjem proizvoda kompanije Veeam.

6. KONTINUITET RADA

6.1. Software-As-A-Service usluga BIS obezbjeđuje kontinuitet rada servisa vodeći se preporukama standarda ISO-22301.

6.2. Visoka dostupnost servisa BIS

6.2.1. Visoka dostupnost SaaS-a BIS garantirana je redundancijom svih kritičnih hardverskih i softverskih komponenti koje služe za pružanje servisa ka krajnjim korisnicima. Tolerirani planirani downtime servisa od dva sata na godišnjem nivou je cilj koji je postignut pažljivo biranim hardverskim i softverskim rješenjima, tehnologijama i najboljim praksama i preporukama.

6.3. Uređaj za pohranu podataka

6.3.1. Redundantni kontroleri uređaja za pohranu podataka za zasebnim naponskim jedinicama, HBA karticama, management portovima – obezbjeđuju visoku dostupnost korisničkih podataka na hard diskovima uređaja za pohranu podataka.

6.3.2. Diskovi su po najboljim praksama konfigurirani u polja diskova sa adekvatnom parity zaštitom koja nas na hardverskom nivou štiti od gubitka podataka uslijed otkaza jednog ili više diskova u okviru diskovnih polja.

6.3.3. Pravilno odabrane konfiguracije diskovnih polja omogućavaju rebuild diskovnih polja u najkraćem mogućem vremenu bez degradacije performansi za izvršavanje operacija čitanja i pisanja na uređaj za pohranu podataka.

6.4. VMware klasterska konfiguracija sa tri hosta za visoku dostupnost virtualnih mašina

- 6.4.1. Uspostavom VMware klasterske konfiguracije od minimalno tri ESX hosta obezbijedena je istinska visoka dostupnost svih virtualnih mašina koje učestvuju u izgradnji SaaS BIS bilo da se radi o stacionarnom režimu rada klastera ili kada se na klasteru izvršavaju poslovi održavanja (maintenance).
- 6.4.2. Lako prebacivanje virtualnih mašina između fizičkih servera korištenjem funkcionalnosti vMotion omogućava da se poslovi redovnog održavanja hardverskih i softverskih komponenti izvode bilo kada i bez bojazni da će na bilo koji način uticati na ispravno funkcioniranje servisa BIS.
- 6.4.3. Mnoge druge tehnologije poput VMware VM Snapshot te pravilno konfigurirane politike zaštite korisničkih i sistemskih podataka osiguravaju gore opisanu visoku dostupnost održivom tijekom cjelokupnog perioda rada servisa BIS.

6.5. Data Protection Server

- 6.5.1. Primarna lokacija za pohranu bekapa virtualnih mašina i korisničkih podataka je zasebni fizički server sa dovoljnim brojem magnetnih diskova konfiguriranih u diskovno polje sa dvostrukom parity zaštitom.
 - 6.5.1.1. Na ovaj način primarna backup lokacija je u potpunosti odvojena od produkcijskog okruženja.
 - 6.5.1.2. Na ovom serveru instaliran je softver renomiranog svjetskog proizvođača Veeam – Veeam Backup and Replication.
- 6.5.2. Data Protection realizira se korištenjem funkcionalnosti “Backup and Restore” na primarnoj lokaciji te korištenjem funkcionalnosti “Data Replication” za repliciranje produkcijskog okruženja na Disaster Recovery site. Dodatno, koristi se i “Backup Copy” funkcionalnost za ostvarenje replikacije kreiranih bekapa sa primarne na DR lokaciju u cilju ostvarenja pravila 4-3-2-1 za čuvanje podataka (tri kopije-dva različita medija-jedna udaljena lokacija, immutable backup).
- 6.5.3. Pored spašavanja virtuelnih mašina svih dobavljača softvera serveri koji pripadaju Dedalus-u se dodatno bekapuju koristeći NFS servere na koje se i sa testnog i sa produkcijskog okruženja radi backup logova Oracle baze svakih 15 minuta.
 - 6.5.3.1. Ovi serveri su dodatno bekapovani u slučaju da NFS file storage naiđe na probleme i konzistentnost podataka se izgubi.
- 6.5.4. Zahtjevi pojedinih dobavljača softvera:
 - 6.5.4.1. WizardLAB – VM level backup + pgBack Rest Postgress
 - 6.5.4.2. Berg – VM level backup
 - 6.5.4.3. Dedalus – VM level backup + Oracle NFS transaction log
 - 6.5.4.4. BBS – VM level backup
 - 6.5.4.5. Argus – VM level backup
 - 6.5.4.6. Racional – VM level backup
 - 6.5.4.7. System – DC, firewall, OOB, FileServer – VM level backup

6.6. Robotizirani Tape Library

- 6.6.1. Ovaj uređaj koristi LTO-8 standard kojim se podaci (bekapi VM-ova, korisnički podaci) smještaju na magnetne trake robotiziranog uređaja sa četiri zasebna magacina i robotiziranim Tape Drive-om za manipulisanje magnetnim trakama. Putem SAS interfejsa Tape Drive je direktno spojen na Data Protection Server.
- 6.6.2. Korištenjem ovakvog uređaja u politici zaštite i čuvanja podataka ostvareno je 4-3-2-1 pravilo, podaci zaštićeni od ransomware napada implementacijom offline storage-a, podaci obezbijedeni za dugoročno čuvanje zbog enormno visokog vijeka trajanja magnetne trake uz adekvatno čuvanje u sefovima sa stabilnim atmosferskim uslovima (kontrolirana temperatura, vlaga).

6.7. Disaster Recovery Server

- 6.7.1. Virtualizirani serveri sa dedicanom fizičkom L3 vezom prema primarnom data centru, dostatnih performansi i neophodnog kapaciteta da u slučaju proglašenja DR scenarija u potpunosti preuzme sav korisnički workload do oporavka servisa u primarnom data centru.
- 6.7.2. Na DR server konfigurirano je polje diskova sa dvostrukom parity zaštitom, adekvatna količina computing i networking resursa da se na ovom server bez degradacije performansi pokrene kompletno produkcijsko okruženje virtualnih mašina primarne lokacije.

6.8. Disaster Recovery Site

- 6.8.1. Disaster Recovery data centar na lokaciji BH Telecom Sarajevo raspolaže sa sljedećim neophodnim uslovima za smještaj DR komponente servisa BIS (kolokacija servera):

6.8.1.1. FIZIČKA ZAŠTITA, NADZOR, PRISTUP

- strogo kontrolisan i siguran data centar
- fizička zaštita (kontrola pristupa, alarmni sistemi)
- nadzor 24/7 (napajanje, klimatizacija, dostupnost)
- objekat otporan na velika opterećenja i utjecaj voda (vlaga, poplava)
- zaštita od požara (vatrodjavni sistem i automatsko gašenje požara)

6.8.1.2. NAPAJANJE I KLIMATIZACIJA

- redundantna klimatizacija sa toplo/hladnim zonama
- neprekidno napajanje (UPS, generator, vlastita trafostanica)
- energetske letve unutar racka - dvostrano redundantno napajanje korisničke opreme

6.8.1.3. PRISTUP KORISNIČKOJ OPREMI

- fizički i konzolni pristup kolociranoj opremi autoriziranim osobama
- korisnik uz smještaj dobiva i dedikirani mrežni pristup svojoj opremi
- udaljeni pristup kolociranoj opremi (internet, postojeća privatna ili metro mreža)

- 6.8.2. Usluga BIS će za implementaciju DR komponente SaaS-a koristiti servere nove generacije koje obezbjeđuje davalac usluge.

- 6.8.3. Zbog visoko postavljenih sigurnosnih politika te činjenice da svu sve storage, computing, networking i security komponente primarnog i DR data centra potpuno virtualizirane u zatvoren sistem, ugovorena je usluga L3 konekcije na DR site-u BIS servisa neophodnog kapaciteta za nesmetano izvršavanje neophodnih replikacija i testiranja DR scenarija u slučaju proglašenja i/ili redovnih testiranja ispravnosti DR scenarija.

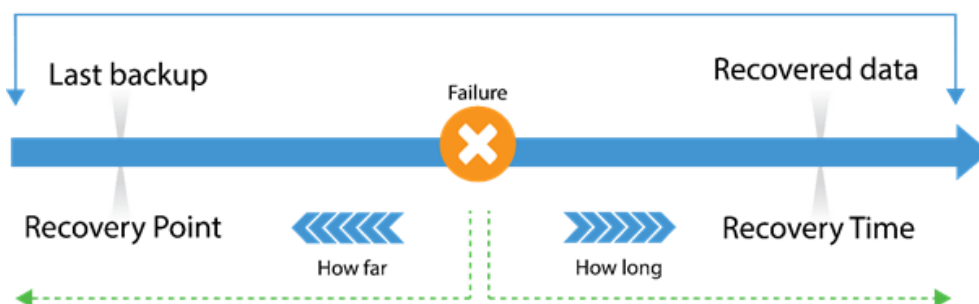
- 6.8.4. Između primarnog i DR data centra uspostavljena je L3 privatna konekcija korištenjem dedicanog rutera samo za potrebe DR-a. DR lokacija je implementirana kao "cold" DR lokacija.

7. POLITIKA ZAŠTITE PODATAKA BIS SERVERA – DATA PROTECTION POLICIES

- 7.1. Korištenjem dokazanog softvera za zaštitu korisničkih podataka i oporavak od katastrofe za VMware virtualizacijska okruženja, Veeam Backup and Replication, implementirane su sljedeće politike zaštite neophodne u ostvarenju Business Continuity i Disaster Recovery plana za servis BIS:

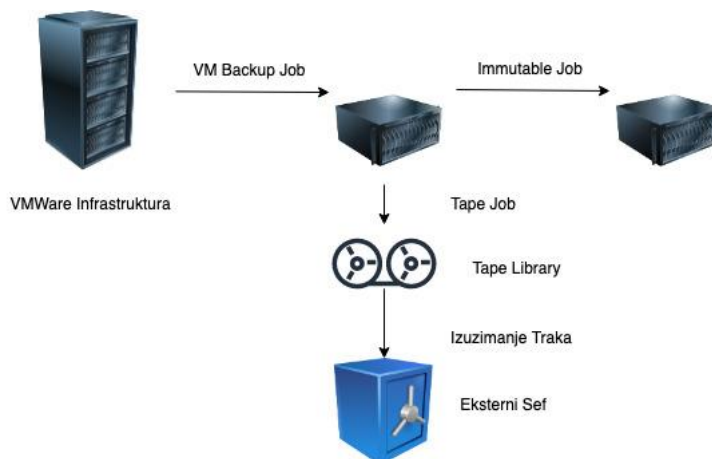
- 7.1.1. politike izrade sigurnosnih kopija svih podataka servisa BIS (Veeam Backup and Restore politike)
- 7.1.2. politike neophodne za ispunjenje Disaster Recovery plana servisa BIS (Veeam Replication politike)
- 7.2.** Veeam Backup and Restore politike u ostvarenju Business Continuity plana obezbjeđuju sljedeće:
 - 7.2.1. prevencija trajnog gubitka podataka uslijed sistemskih, administratorskih i hardverskih grešaka, bilo da je riječ o korisničkim, konfiguracionim i drugim neophodnim podacima za pružanje servisa BIS
 - 7.2.2. periodičnu izradu sigurnosnih kopija svih virtualnih mašina servisa BIS (VM image-based backup) sa trajnim čuvanjem podataka korisnika servisa BIS uz poštovanje pravila 4-3-2-1 (tri kopije, dva različita medija, jedna udaljena lokacija, immutable kopija)
 - 7.2.3. replikacija kreiranih sigurnosnih kopija podataka (backup-a) na Disaster Recovery Site korištenjem Veeam Backup Copy Job funkcionalnosti
 - 7.2.4. garancija na konzistentnost bekapiranih podataka na nivou operativnog sistema
 - 7.2.5. RPO (Recovery Point Objective) od jednog sata za sve virtualne mašine servisa BIS
 - 7.2.6. RTO (Recovery Time Objective) od jednog sata bez obzira na broj virtualnih mašina i količinu podataka koje oporavljamo korištenjem funkcionalnosti Veeam softvera pod nazivom "Veeam Instant Recovery"
 - 7.2.7. Restore pojedinačnih fajlova, foldera, virtualnih diskova, virtualnih mašina i/ili grupa virtualnih mašina
 - 7.2.8. izmještanje magnetnih traka u namjenski sef kako bi se osiguralo smještanje korisničkih podataka na tzv. offline storage čime se reducira potencijalna prijetnja od sve učestalijih ransomware napada
 - 7.2.9. direktan restore korisničkih podataka sa magnetnih traka na produkcijsko okruženje servisa BIS

7.3. Na slici ispod ilustrirano je značenje parametara RTO i RPO:



- 7.4.** Obzirom da je dio virtuelnih mašina servisa BIS bazirano na operativnom sistemu Windows iskorištena je puna integracija Veeam softvera sa Windows operativnim sistemom za zadovoljenje pomenute konzistencije podataka na nivou operativnog sistema (VSS – Volume Shadow-Copy Service).
- 7.5.** Izrada sigurnosnih kopija podataka po principu 4-3-2-1 (tri kopije, dva različita medija, jedna udaljena lokacija, immutable kopija) implementirana je na način da se prva sigurnosna kopija pohranjuje na zaseban fizički Data Protection server sa dvostrukom parity zaštitom diskovnog polja, druga sigurnosna kopija se sprema na magnetne trake LTO-8 putem robotiziranog Tape Library uređaja (dva različita medija podataka – disk i traka) te treća sigurnosna kopija spremljena na DR udaljenoj lokaciji putem Veeam Backup Copy Job-ova sa Data Protection servera na standalone server na DR lokaciji sa diskovnim poljem sa dvostrukom parity zaštitom.

- 7.6.** Četvrta lokacija za spremanje podataka nalazi se na specijaliziranom “hardened” Veeam repository-u koji koristi izdvojeni NAS uređaj i linux server koji se nalazi na izdvojenom server u odvojenom VLAN-u. Kopije koje se nalaze na ovom repository-u imaju postavljen immutability flag na kopijama od 7 dana. Ova kopija se takođe može koristiti za instant restore metod obzirom da se linux server nalazi na 10 gigabitnoj mreži direktno spojenoj na core switch.
- 7.7.** Veeam Replication politike u ostvarenju Disaster Recovery plana obezbijavaju sljedeće:
- 7.7.1. potpuni oporavak rada servisa BIS na Disaster Recovery lokaciji u slučaju ispada primarnog sajta uslijed katastrofe (zemljotresi, poplave, dugotrajni gubitak napajanja, prekid ISP komunikacije oba ISP-a) a prema unaprijed postavljenom i periodično testiranom DR planu oporavka od katastrofe
 - 7.7.2. manualni failover/failback između primarnog i DR sajta sa ovlaštenom osobom iz DR plana koja proglašava stanje katastrofe i aktivaciju DR plana
 - 7.7.3. replikacija svih virtualnih mašina servisa BIS (VM image-based replication) na Disaster Recovery Site putem dedisirane hardverske L3 veze dostatne propusnosti koja omogućava ispunjenje postavljenih RTO i RPO parametara DR plana
 - 7.7.4. RPO replikacije virtualnih mašina je postavljen na jedan sat
 - 7.7.5. RTO svih repliciranih virtualnih mašina koje sačinjavaju servis BIS je postavljen na jedan sat
- 7.8.** Sve virtualne mašine servisa BIS se sa primarnog sajta repliciraju na DR sajt. Ove virtualne mašine su na DR sajtu uvijek ugašene prilikom replikacije podataka i kao takve odgovaraju sigurnosnoj politici potpune zatvorenosti korisničkih podataka na DR lokaciji – Cold Replication.
- 7.8.1. Jedina aktivna komponenta na DR lokaciji je Veeam Backup Restore virtualna mašina. Ovako konfigurisano rješenje garantira da je na DR sajtu moguć oporavak BIS servisa potpuno neovisno o primarnom sajtu u slučaju katastrofe.
- 7.9.** Kvalitativna provjera uspješnosti replikacije odnosno testiranje DR scenarija radi se putem Veeam funkcionalnosti SureBackup. Ova funkcionalnost skenira replicirane podatke na različite malware prijetnje u izolovanom okruženju te za sve vrijeme obrade svi korisnički podaci ostaju u “read-only” mode-u.
- 7.10.** U cilju obezbjeđenja konzistentnosti arhiviranih korisničkih podataka mandatorno je da kompletno SaaS rješenje BIS u potpunosti poštuje princip zatvorenosti korisničkih podataka na svim stranama osim primarne strane na koju dolaze korisnički zahtjevi.
- 7.11.** Na slici ispod šematski su prikazane gore opisane BC i DR politike u zasebnim data centrima za pružanje SaaS-a BIS:



8. REVIZIJA

8.1. Revizija ove politike se vrši minimalno jednom u tri godine ili po potrebi ukoliko dođe do tehničkih promjena u HIS sistemu, promjena regulatornog okvira ili identifikacije sigurnosnih prijetnji.

Prilagodili:	
Stručni saradnik za kvalitet	Menadžer informacionih tehnologija
Amar Smajić 	Enes Hatibović 